Software Requirements Specification (SRS)

Simplified GDPR Consent Manager

Project: Simplified GDPR Consent Manager
Team: Team 6
Version: 1.0
Authors: Team 6 (see team members below)
Date: 05-10-2026

Team Members

#	Name	SRN
1	VILAS	PES1UG24AM415
2	SUMAN DIDDIMANI	PES1UG24AM409
3	PRANAAV PRABHAKARAN	PES1UG24AM387
4	PRADEEP T	PES1UG24AM385

Revision History

Version	Date	Author	Change Summary	Approval
1.0	05-10-2026	Team 6	Complete SRS with requirements, Draw.io UML use-case diagrams and RTM	Submitted

Approvals

Role	Name	Signature / Email	Date
Course Coordinator			

Table of Contents

1. Introduction
2. Overall Description
3. External Interface Requirements
4. System Features (Detailed)
5. Non-Functional Requirements (Detailed)
6. Quality Attributes & Acceptance Tests
7. UML Use-Case Diagrams
8. Requirements Traceability Matrix (RTM)

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional, non-functional and security requirements of the Simplified GDPR Consent Manager. The system is a web-based consent-logging and consent-management application that allows users to provide, review and withdraw consent for individual data-processing purposes.

The system keeps a complete, append-only history of every consent decision, records the timestamp and the policy version associated with each decision, and maintains an audit trail of important consent, policy and administrative activities so that authorised reviewers can trace who consented to what, when, and under which policy.

The Simplified GDPR Consent Manager is an academic software-engineering project. It demonstrates software concepts that support GDPR-style consent management; it does not by itself guarantee or certify legal GDPR compliance for any organisation.

1.2 Scope

The Simplified GDPR Consent Manager is a web-based application for managing and recording user consent for data processing. The system covers:

- Displaying the active data-processing purposes for which consent may be requested.
- Allowing users to opt in to individual data-processing purposes.
- Allowing users to withdraw (opt out of) previously granted consent at any time.
- Recording the date and time (UTC) of every consent action.
- Maintaining the current consent status of each user for each processing purpose.
- Maintaining a complete consent history instead of overwriting earlier decisions.
- Associating each consent decision with the policy version presented to the user.
- Allowing authorised administrators to create, version and publish consent policies, while protecting historical policy versions from modification.
- Maintaining an audit trail of security-, consent- and administration-related activities.
- Allowing the DPO/Auditor to search, filter and review consent records, policy versions and the audit trail.
- Determining the consent state that applied to a user at a specified point in time.
- Preventing unauthorised users from accessing or modifying protected records.

Out of scope

The following are outside the scope of this version:

- Actual processing of personal data by the organisation or by third parties.
- Legal advice, automated legal interpretation of GDPR, or automatic determination of an organisation's GDPR compliance.
- Automatic generation of legally binding privacy policies.
- Integration with real-world regulator or government systems.
- Payment processing, enterprise identity management (SSO/LDAP) and biometric authentication.
- Collection or storage of special-category or other unnecessary sensitive personal data.

These boundaries keep the project implementable by a student team within two sprints while still demonstrating the core concepts of consent management.

1.3 Audience

- Project development team (Team 6) responsible for implementing the system.
- QA/test team responsible for verifying the requirements in this document.
- Project guide and course faculty evaluating the software-engineering artefacts.
- Administrators and Data Protection Officers (DPOs)/Auditors represented by the system roles.
- End users who provide or withdraw consent.
- Future maintainers who may extend the consent-management system.

1.4 Definitions and Acronyms

Term	Meaning
GDPR	General Data Protection Regulation (EU) 2016/679.
Data Subject / User	The person whose consent is being recorded; the end user of the system.
Consent	A user's recorded, explicit permission for a specified data-processing purpose.
Opt-in	An affirmative action through which a user grants consent for a purpose.
Opt-out / Withdrawal	An action through which a user withdraws previously granted consent.
Processing Purpose	A specific, named purpose for which personal data may be processed (e.g. marketing e-mails).
Consent Record	An immutable stored record of one consent decision (user, purpose, action, timestamp, policy version).
Consent Status	The latest consent decision of a user for a purpose: Granted, Withdrawn or Not given.
Consent History	The chronological, append-only collection of a user's consent records.
Policy Version	A uniquely identified version of the privacy/consent policy; states: Draft, Published, Superseded.
Audit Trail	Append-only chronological log of security-, consent- and administration-related events.
Historical Consent State	The consent status that applied to a user at a specified past date/time.
DPO	Data Protection Officer; in this system, the read-only compliance reviewer role (DPO/Auditor).
Admin	Authorised system administrator.
RBAC	Role-Based Access Control.
UTC	Coordinated Universal Time; the time base used for all stored timestamps.
API / UI	Application Programming Interface / User Interface.
SRS / SAD / STP	Software Requirements Specification / Software Architecture and Design / Software Test Plan.
RTM	Requirements Traceability Matrix.

2. Overall Description

2.1 Product Perspective

The Simplified GDPR Consent Manager is a new, self-contained web application. It follows a three-tier structure: a responsive browser-based front end, a backend application exposing a REST (JSON over HTTPS) API, and a relational database that stores users, processing purposes, policy versions, consent records and audit entries.

Consent records and audit entries are stored as append-only data: every new decision or event creates a new row and no application function updates or deletes earlier rows. The current consent status and any historical consent state are derived from this history. In a real deployment, other applications of the organisation could query the stored consent status before processing data; such integrations are not part of this version.

2.2 Major Product Functions

1. Authenticate users and enforce role-based access for User, Administrator and DPO/Auditor.
2. Present active processing purposes and the currently published privacy/consent policy.
3. Record explicit opt-in and opt-out (withdrawal) decisions per processing purpose.
4. Record a UTC timestamp and the associated policy version with every consent decision.
5. Show each user their current consent status and complete consent history.
6. Allow administrators to manage processing purposes, users and roles.
7. Allow administrators to create, version and publish policies, and protect historical versions.
8. Maintain an append-only audit trail of important events.
9. Allow the DPO/Auditor to search and filter consent records, policy versions and audit entries.
10. Reconstruct the consent state of a user at any past point in time.

2.3 User Roles and Characteristics

Role	Responsibilities and characteristics
User (Data Subject)	Registers and logs in; views processing purposes and the current policy; grants and withdraws consent; views own consent status and history. Basic web literacy; no technical or legal knowledge assumed.
Administrator	Manages processing purposes, user accounts and roles; creates and publishes policy versions; reviews administrative activity. Technically competent; cannot alter consent records.
DPO / Auditor	Read-only compliance reviewer: views and searches consent records, consent history, policy versions and the audit trail, and retrieves historical consent states. Familiar with data-protection concepts.

2.4 Operating Environment

- Client: current versions of Google Chrome, Mozilla Firefox, Microsoft Edge and Safari on desktop/laptop, Android and iOS devices (responsive layout, minimum width 360 px).
- Server: Linux or Windows host (or container) running the backend runtime selected in the SAD.
- Database: a relational database such as PostgreSQL or MySQL.
- Network: HTTPS access over the Internet or a campus network; server clock synchronised via NTP.

2.5 Constraints

- The system is a simplified academic implementation; it supports consent-management practices but does not guarantee or certify legal GDPR compliance.
- Only the minimum personal data needed for the system is stored: name, e-mail address, password hash, role and consent/audit records.
- Consent records, published policy versions and audit entries are append-only and must never be edited or deleted through the application.
- All timestamps are stored in UTC.
- The system must be implemented with open-source technologies and delivered by a four-member team within the two planned sprints (19-23 Oct 2026 and 26-30 Oct 2026), with source code and CI on GitHub.
- Real third-party processors, e-mail campaigns and regulator integrations are simulated or out of scope.

3. External Interface Requirements

3.1 User Interfaces

A responsive web interface with role-controlled screens. Each role sees only the screens and actions permitted to it:

- Login and registration screens.
- User consent dashboard: list of active purposes with their descriptions, current consent status and Grant/Withdraw controls, plus a link to the current policy.
- Policy view screen showing version number, effective date and full policy text.
- Consent history screen (reverse chronological).
- Administrator console: processing purposes, policy versions (draft/publish), users and roles, administrative activity.
- DPO/Auditor console: consent records, audit trail, policy versions, search/filter and historical consent-state lookup.

3.2 Hardware / Device Interfaces

No special hardware is required. Users access the system from standard desktops, laptops, tablets or smartphones with a web browser. The server requires a standard host or virtual machine with persistent storage for the database and backups.

3.3 Software Interfaces

- Relational database (PostgreSQL/MySQL) accessed by the backend through parameterised queries or an ORM.
- REST API (JSON over HTTPS) between the web front end and the backend.
- Operating-system time service synchronised with NTP for accurate consent and audit timestamps.
- GitHub and GitHub Actions for version control and continuous integration (development environment).

3.4 Communications

All client-server communication shall use HTTPS (HTTP over TLS 1.2 or later, carried over TCP - RFC 9293). Plain HTTP requests shall be redirected to HTTPS. Request and response bodies use JSON encoded in UTF-8.

4. System Features (Detailed)

Each requirement below includes acceptance criteria and a reference test case. Functional requirement IDs follow FR-n; security requirements (SEC-n) and non-functional requirements (NFR-n) are listed separately in Section 5.

4.1 Authentication and Access

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-1	The system shall allow a new user to register with name, e-mail address and password, and shall assign the User role to every self-registered account.	Functional	High	User	A valid registration creates one account with the User role; a duplicate e-mail is rejected.	TC-AUTH-01
FR-2	The system shall allow a registered user to log in with e-mail address and password and shall open the home screen corresponding to the user's role.	Functional	High	All users	Valid credentials create an authenticated session and open the role's home screen; invalid credentials are rejected.	TC-AUTH-02
FR-3	The system shall allow a logged-in user to log out, ending the session immediately.	Functional	Medium	All users	After logout, protected pages and API calls with the old session return 'unauthenticated'.	TC-AUTH-03

4.2 Consent Purpose and Policy Presentation

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-4	The system shall allow an authenticated user to view all active data-processing purposes together with each purpose's name, description and the user's current consent status.	Functional	High	User	All active purposes are displayed with name, description and current state (Granted, Withdrawn or Not given).	TC-CONS-01
FR-5	The system shall display the currently published privacy/consent policy, including its version number, effective date and full text, to any authenticated user.	Functional	High	User	The displayed policy matches the single published version, including version number and effective date.	TC-CONS-02
FR-6	The system shall allow an Administrator to create, edit and deactivate processing purposes; a deactivated purpose shall no longer be offered to users but its consent history shall be retained.	Functional	High	Administrator	Purpose changes are saved; a deactivated purpose disappears from user screens while its existing records remain retrievable.	TC-PURP-01

4.3 Opt-in / Opt-out Consent Management

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-7	The system shall allow a user to grant consent (opt in) for an individual processing purpose through an explicit affirmative action; no purpose shall be pre-selected as granted.	Functional	High	User	Consent is recorded only after the user actively selects Grant; new purposes default to 'Not given'.	TC-CONS-03
FR-8	The system shall allow a user to withdraw (opt out of) previously granted consent for a purpose at any time, using no more steps than were needed to grant it.	Functional	High	User	Withdrawal is recorded and the purpose status changes to 'Withdrawn' immediately.	TC-CONS-04
FR-9	The system shall store, for every consent decision, the user ID, purpose ID, action (Granted / Withdrawn), UTC timestamp and the identifier of the policy version in effect when the decision was made.	Functional	High	DPO / Auditor	Every stored consent record contains all five fields and the policy version equals the version published at that time.	TC-CONS-05
FR-10	The system shall reject a consent action for an inactive purpose, when no policy version is published, or when the action would not change the current status, and shall show an explanatory message.	Functional	Medium	User	Each invalid action is rejected with a message and no consent record is created.	TC-CONS-06

4.4 Consent History and Traceability

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-11	The system shall store consent decisions as append-only records: each new decision shall create a new record and shall never overwrite or delete an earlier record.	Functional	High	DPO / Auditor	After grant, withdraw and re-grant, three separate records exist and earlier records are unchanged.	TC-HIST-01
FR-12	The system shall allow a user to view his or her own consent history in reverse chronological order, showing purpose, action, timestamp and policy version for each entry.	Functional	Medium	User	The history lists all of the user's records, newest first, with all four fields and no other user's data.	TC-HIST-02

4.5 Policy Version Management

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-13	The system shall allow an Administrator to create a new policy version as a Draft with a unique version number, title, policy text and change summary; a Draft may be edited until it is published.	Functional	High	Administrator	A Draft is saved with a unique version number; a duplicate version number is rejected.	TC-POL-01
FR-14	The system shall allow an Administrator to publish a Draft version; publishing shall set its effective timestamp, make it the only Published version and mark the previous version as Superseded.	Functional	High	Administrator	After publishing, exactly one version is Published, the previous one is Superseded and new consents reference the new version.	TC-POL-02
FR-15	The system shall retain every Published and Superseded policy version, allow Administrators and the DPO/Auditor to view any version, and prevent such versions from being edited or deleted.	Functional	High	DPO / Auditor	All versions are listed and viewable; edit or delete attempts on Published/Superseded versions are refused.	TC-POL-03
FR-16	When a new policy version is published, the system shall notify each user who has consents linked to an older version on the next login and offer the option to review and re-confirm or withdraw those consents.	Functional	Medium	User	Affected users see the review notice on next login; existing consent records are not altered by the publication.	TC-POL-04

4.6 Audit Trail and Compliance Review

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-17	The system shall write an audit-trail entry for each login success/failure, consent grant/withdrawal, purpose change, policy creation/publication and user/role change, recording actor, action, target, UTC timestamp and outcome.	Functional	High	DPO / Auditor	Each listed event type produces exactly one audit entry containing all five fields.	TC-AUD-01
FR-18	The system shall allow the DPO/Auditor to view all consent records, consent histories and the audit trail in read-only mode, and allow an Administrator to view audit entries of administrative actions.	Functional	High	DPO / Auditor	DPO/Auditor sees all records with no edit controls; Administrator sees administrative audit entries only.	TC-AUD-02

4.7 Search and Historical State Retrieval

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria	Test case ref
FR-19	The system shall allow the DPO/Auditor to search and filter consent records and audit entries by user, purpose, action, policy version and date range, with paginated results.	Functional	Medium	DPO / Auditor	Each filter, alone and combined, returns only matching records; results are paginated.	TC-SRCH-01
FR-20	The system shall allow the DPO/Auditor to retrieve the consent state of a selected user for one or all purposes as of a specified past date and time, together with the policy version that applied.	Functional	High	DPO / Auditor	For a known test history, the returned state and policy version match the last decision made at or before the given instant.	TC-SRCH-02

5. Non-Functional Requirements (Detailed)

5.1 Security

5.1.1 Security Objectives

- **SO-1:** Ensure that only authenticated and authorised users can access the functions and data appropriate to their roles (User, Administrator, DPO/Auditor).
- **SO-2:** Protect consent, policy and audit records, and user credentials, against unauthorised disclosure or modification.
- **SO-3:** Ensure accountability: every consent decision and every security- or administration-relevant action can be attributed to an actor and a point in time.

5.1.2 Security Requirements

Req ID	Security requirement	Type	Priority	Source basis	Acceptance criteria	Test case ref
SEC-1	Users shall authenticate with a unique e-mail address and password; passwords shall be at least 8 characters and stored only as salted adaptive hashes (bcrypt or Argon2).	Security	High	Authentication / credential protection	Login works only with valid credentials; the database contains no plaintext or reversible passwords.	TC-SEC-01
SEC-2	Access to every screen and API endpoint shall be enforced on the server by role (User, Administrator, DPO/Auditor); a User shall access only his or her own consent data.	Security	High	Role-based access control	Requests outside a role's permissions, or for another user's data, return HTTP 403 and are audited.	TC-SEC-02
SEC-3	An account shall be locked for 15 minutes after 5 consecutive failed login attempts, and sessions shall expire after 15 minutes of inactivity.	Security	Medium	Account protection	The sixth attempt within the lock period is refused; an idle session is invalid after 15 minutes.	TC-SEC-03
SEC-4	Only an Administrator shall be able to create, deactivate and change the role of user accounts; every role change shall be audited and no role shall be able to modify consent records.	Security	High	User account administration	Administrator can manage accounts and roles; each change creates an audit entry; non-admins are refused.	TC-SEC-04
SEC-5	All communication between client and server shall use HTTPS with TLS 1.2 or later; plain HTTP requests shall be redirected to HTTPS.	Security	High	Data in transit	TLS scan shows only TLS 1.2+; an HTTP request receives a redirect to HTTPS.	TC-SEC-05

Req ID	Security requirement	Type	Priority	Source basis	Acceptance criteria	Test case ref
SEC-6	Consent records, Published/Superseded policy versions and audit entries shall not be modifiable or deletable through any application function or API, and the DPO/Auditor role shall be read-only.	Security	High	Record integrity	All update/delete attempts on protected records are refused with HTTP 403/405 and the records are unchanged.	TC-SEC-06
SEC-7	The system shall validate all input and protect against SQL injection, cross-site scripting and cross-site request forgery (parameterised queries, output encoding, anti-CSRF tokens).	Security	High	Secure coding (OWASP Top 10)	Injection, XSS and CSRF test payloads are rejected or neutralised with no data change.	TC-SEC-07

5.2 Non-Functional Requirements

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria / Measurement	Test case ref
NFR-1	A consent grant or withdrawal shall be saved and the updated status shown to the user within 2 seconds.	Performance	High	User	At least 95% of consent actions complete within 2 s with 50 concurrent users.	TC-PERF-01
NFR-2	Search/filter results (first page of 50 rows) shall be returned within 3 seconds.	Performance	Medium	DPO / Auditor	At least 95% of test queries over 100,000 consent records return within 3 s.	TC-PERF-02
NFR-3	The system shall support at least 50 concurrent users, 10,000 registered users and 500,000 consent records while meeting NFR-1 and NFR-2.	Scalability	Medium	System capacity	Load test at the stated volumes meets the NFR-1 and NFR-2 targets.	TC-SCAL-01
NFR-4	The system shall be available for at least 99% of the scheduled demonstration and evaluation hours in a month.	Availability	Medium	Course faculty / Users	Uptime monitoring over the evaluation period shows at least 99% availability.	TC-REL-01
NFR-5	Each consent action shall be atomic: the consent record and its audit entry shall be committed together or not at all.	Reliability	High	DPO / Auditor	Fault-injection tests leave no consent record without its audit entry and vice versa.	TC-REL-02

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria / Measurement	Test case ref
NFR-6	A first-time user shall be able to grant or withdraw consent for a purpose within 1 minute and at most 3 clicks after login, without help.	Usability	Medium	User	At least 4 of 5 first-time test participants complete the task within the limits.	TC-UX-01
NFR-7	User-facing screens shall meet the main WCAG 2.1 AA checks: keyboard operation, labelled form controls and a text contrast ratio of at least 4.5:1.	Usability / Accessibility	Low	User	An automated accessibility checker and a manual keyboard test report no AA violations on user screens.	TC-UX-02
NFR-8	Consent records, policy versions and audit entries shall be retained for at least a configurable retention period (default 3 years) and shall not be removed by routine operations.	Data retention	Medium	DPO / Auditor	The retention setting exists with a 3-year default; no routine job deletes records younger than the period.	TC-DATA-01
NFR-9	The system shall store only the personal data it needs (name, e-mail, password hash, role, consent and audit data); logs shall not contain passwords or session tokens.	Privacy / Data minimisation	High	Users / DPO	A schema and log review finds no extra personal-data fields and no secrets in logs.	TC-PRIV-01
NFR-10	Personal data stored in the database (e-mail addresses) and database backups shall be encrypted at rest.	Security	Medium	Users / DPO	Inspection of storage and a backup file shows the protected data is not readable in plaintext.	TC-SEC-08
NFR-11	The database shall be backed up daily (recovery point 24 hours) and a restore shall be completed within 4 hours; a restore shall be tested before release.	Recovery	Medium	System administratio n	A scheduled daily backup exists and a restore test completes within 4 hours with no loss of backed-up records.	TC-REL-03
NFR-12	The code shall follow a layered structure (UI, API, service, data access); the service layer shall have at least 70% automated unit-test coverage, run in GitHub Actions on every pull request.	Maintainability	Medium	Development team	The CI report shows passing tests and at least 70% service-layer coverage.	TC-MAINT-01

Req ID	Requirement	Type	Priority	Stakeholder	Acceptance criteria / Measurement	Test case ref
NFR-13	All stored timestamps shall be in UTC from an NTP-synchronised clock and shall be displayed in the viewer's local time zone.	Reliability / Data accuracy	Medium	DPO / Auditor	Stored values are UTC; the server clock is NTP-synchronised; the UI displays correctly converted local time.	TC-DATA-02
NFR-14	Every functional, security and non-functional requirement shall be traceable to at least one test case in the RTM.	Traceability	Medium	QA / Assessment	The RTM contains a test reference for every FR, SEC and NFR.	TC-RTM-01

6. Quality Attributes & Acceptance Tests

6.1 Quality Attributes

The following quality attributes are most important for a consent-management system. Each is linked to the requirements that specify it and to the way it will be measured or tested.

Quality attribute	Goal	Related requirements	Measurement / test method
Security	Only authorised roles can reach functions and data; credentials and traffic are protected.	SEC-1 to SEC-7, NFR-10	Role-permission test matrix, failed-login and session-timeout tests, TLS scan, OWASP ZAP baseline scan.
Integrity	Consent, policy and audit records cannot be altered or lost.	FR-11, FR-15, SEC-6, NFR-5	Attempted update/delete through UI and API; fault-injection during consent save; database row comparison before/after.
Performance	Consent actions and searches respond quickly under expected load.	NFR-1, NFR-2, NFR-3	Load test (e.g. JMeter/k6) with 50 virtual users over seeded data; 95th-percentile response times.
Reliability	The system is available during evaluation and can be recovered from backup.	NFR-4, NFR-11, NFR-13	Uptime monitoring log; backup/restore drill timed against the 4-hour target; clock-sync check.
Usability	Users can manage consent easily and accessibly.	NFR-6, NFR-7, FR-8	Task-based test with 5 first-time participants; automated accessibility checker plus keyboard-only walkthrough.
Privacy	Only minimal personal data is stored and it is protected.	NFR-9, NFR-10, NFR-8	Schema and log review against the data inventory; inspection of encrypted fields and backups.
Traceability	Every consent decision and requirement can be traced.	FR-9, FR-17, FR-20, NFR-14	Verify policy version and audit link for sample decisions; historical-state replay test; RTM completeness check.

6.2 Acceptance Test Suites

- Authentication and access tests (TC-AUTH-01 to TC-AUTH-03).
- Consent purpose, policy presentation and opt-in/opt-out tests (TC-PURP-01, TC-CONS-01 to TC-CONS-06).
- Consent history and policy version tests (TC-HIST-01, TC-HIST-02, TC-POL-01 to TC-POL-04).

- Audit trail, search and historical-state tests (TC-AUD-01, TC-AUD-02, TC-SRCH-01, TC-SRCH-02).
- Security tests (TC-SEC-01 to TC-SEC-08).
- Performance, scalability and reliability tests (TC-PERF-01, TC-PERF-02, TC-SCAL-01, TC-REL-01 to TC-REL-03).
- Usability, privacy, data, maintainability and traceability tests (TC-UX-01, TC-UX-02, TC-PRIV-01, TC-DATA-01, TC-DATA-02, TC-MAINT-01, TC-RTM-01).

6.3 Acceptance Exit Criteria

The system will be accepted when all of the following hold:

- All High-priority functional and security requirements are implemented and their test cases pass.
- No open defect of Critical or High severity; any Medium defects are documented with a workaround.
- No failure of a High-priority NFR; any Medium/Low NFR deviation is documented and agreed with the project guide.
- Consent-history and audit-trail integrity tests (TC-HIST-01, TC-SEC-06, TC-REL-02) pass with zero discrepancies.
- The RTM shows a test case for every requirement and the status of every requirement is P (Passed) or A (Accepted).

7. UML Use-Case Diagrams

The diagrams below were created in Draw.io (diagrams.net); the editable source files are GDPR_User_Consent_UseCase.drawio and GDPR_Admin_Auditor_UseCase.drawio.

7.1 User Consent Workflow

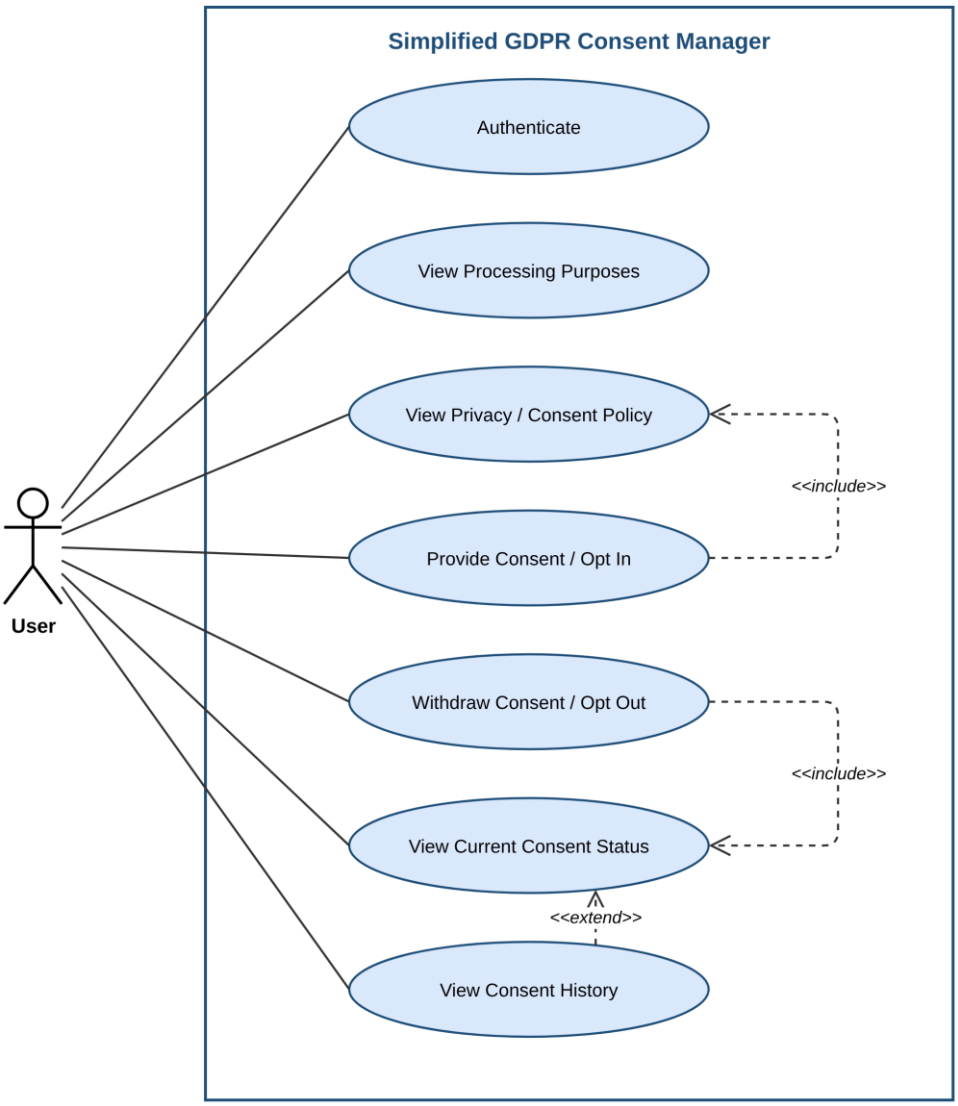


Figure 1. User Consent Workflow Use-Case Diagram.

7.2 Administration and Audit

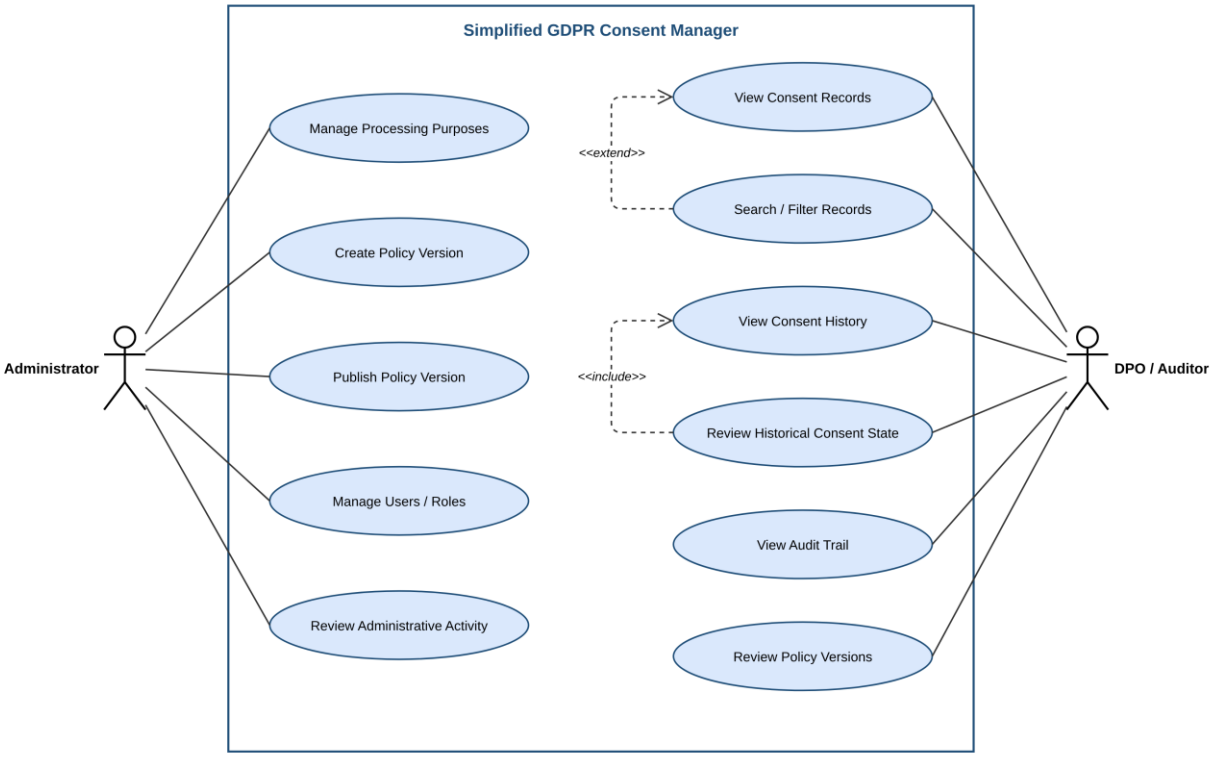
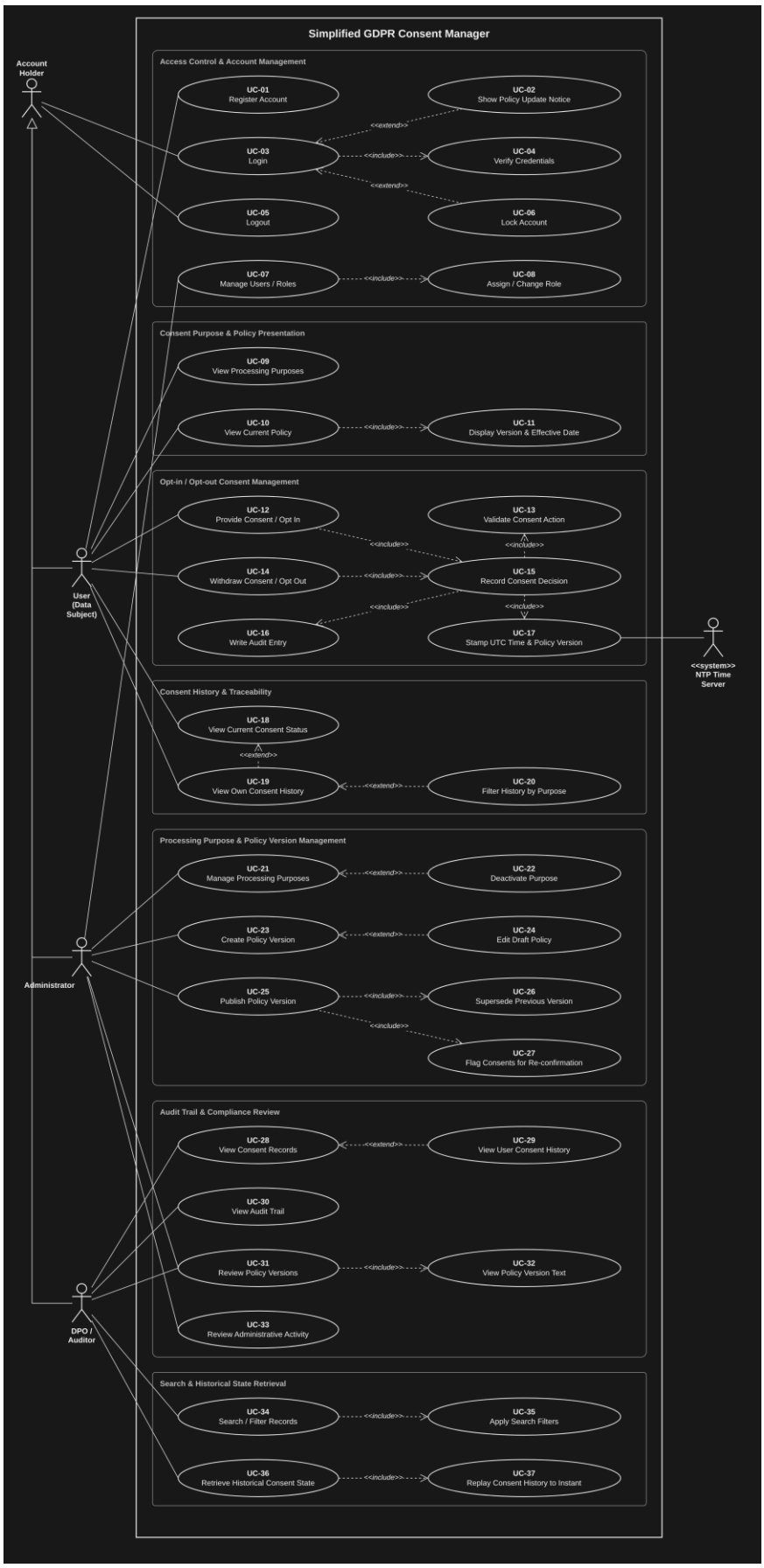


Figure 2. Administration and Audit Use-Case Diagram.

UML DIAFRAM(DRAWIO):



7.3 Use-Case to Requirement Mapping

Use case	Actor(s)	Requirements realised
Authenticate	User, Administrator, DPO / Auditor	FR-1, FR-2, FR-3, SEC-1, SEC-3
View Processing Purposes	User	FR-4
View Privacy / Consent Policy	User	FR-5, FR-16
Provide Consent / Opt In	User	FR-7, FR-9, FR-10
Withdraw Consent / Opt Out	User	FR-8, FR-9, FR-10
View Current Consent Status	User	FR-4
View Consent History	User, DPO / Auditor	FR-11, FR-12, FR-18
Manage Processing Purposes	Administrator	FR-6
Create Policy Version	Administrator	FR-13
Publish Policy Version	Administrator	FR-14, FR-16
Manage Users / Roles	Administrator	SEC-4
Review Administrative Activity	Administrator	FR-17, FR-18
View Consent Records	DPO / Auditor	FR-18
Search / Filter Records	DPO / Auditor	FR-19
View Audit Trail	DPO / Auditor	FR-17, FR-18
Review Policy Versions	DPO / Auditor	FR-15
Review Historical Consent State	DPO / Auditor	FR-20

8. Requirements Traceability Matrix (RTM)

Status values: N = Not yet verified, P = Passed, A = Accepted. Functional (FR), security (SEC) and non-functional (NFR) requirement IDs are separate, so no requirement appears twice.

Req ID	Section ref	Module / Design area	Test case(s)	Status
FR-1	4.1	Authentication	TC-AUTH-01	N
FR-2	4.1	Authentication	TC-AUTH-02	N
FR-3	4.1	Authentication	TC-AUTH-03	N
FR-4	4.2	Consent Purpose & Policy Service	TC-CONS-01	N
FR-5	4.2	Consent Purpose & Policy Service	TC-CONS-02	N
FR-6	4.2	Consent Purpose & Policy Service	TC-PURP-01	N
FR-7	4.3	Consent Management Service	TC-CONS-03	N
FR-8	4.3	Consent Management Service	TC-CONS-04	N
FR-9	4.3	Consent Management Service	TC-CONS-05	N
FR-10	4.3	Consent Management Service	TC-CONS-06	N
FR-11	4.4	Consent History Service	TC-HIST-01	N
FR-12	4.4	Consent History Service	TC-HIST-02	N
FR-13	4.5	Policy Version Service	TC-POL-01	N
FR-14	4.5	Policy Version Service	TC-POL-02	N
FR-15	4.5	Policy Version Service	TC-POL-03	N
FR-16	4.5	Policy Version Service	TC-POL-04	N
FR-17	4.6	Audit & Compliance Review	TC-AUD-01	N
FR-18	4.6	Audit & Compliance Review	TC-AUD-02	N
FR-19	4.7	Search & Historical State Service	TC-SRCH-01	N
FR-20	4.7	Search & Historical State Service	TC-SRCH-02	N
SEC-1	5.1.2	Security	TC-SEC-01	N
SEC-2	5.1.2	Security	TC-SEC-02	N
SEC-3	5.1.2	Security	TC-SEC-03	N
SEC-4	5.1.2	Security	TC-SEC-04	N
SEC-5	5.1.2	Security	TC-SEC-05	N
SEC-6	5.1.2	Security	TC-SEC-06	N
SEC-7	5.1.2	Security	TC-SEC-07	N
NFR-1	5.2	Performance	TC-PERF-01	N
NFR-2	5.2	Performance	TC-PERF-02	N
NFR-3	5.2	Scalability	TC-SCAL-01	N
NFR-4	5.2	Availability	TC-REL-01	N
NFR-5	5.2	Reliability	TC-REL-02	N
NFR-6	5.2	Usability	TC-UX-01	N
NFR-7	5.2	Usability / Accessibility	TC-UX-02	N
NFR-8	5.2	Data retention	TC-DATA-01	N
NFR-9	5.2	Privacy / Data minimisation	TC-PRIV-01	N
NFR-10	5.2	Security	TC-SEC-08	N

Req ID	Section ref	Module / Design area	Test case(s)	Status
NFR-11	5.2	Recovery	TC-REL-03	N
NFR-12	5.2	Maintainability	TC-MAINT-01	N
NFR-13	5.2	Reliability / Data accuracy	TC-DATA-02	N
NFR-14	5.2	Traceability	TC-RTM-01	N